

IAM Control Crosswalk

IAM Control Area	Control Objective	ISO/IEC 27001:2022 Reference	NIST CSF 2.0 Reference	Why Relevant
Access Authorization (CO-01)	Access is granted only through an approved and controlled authorization process	Annex A 5.18 - Access rights	PR.AA — Identity Management, Authentication, and Access Control	Ensures access is provisioned based on authorization and defined business requirements
Least Privilege (CO-02)	Access is limited to the permissions required for the user's role	Annex A 5.15 - Access control	PR.AA — Identity Management, Authentication, and Access Control	Reduces unnecessary access and limits the potential impact of compromised accounts
Periodic Access Review (CO-03)	User access is periodically reviewed to confirm it remains appropriate	Annex A 5.18 - Access rights	PR.AA — Identity Management, Authentication, and Access Control	Ensures outdated, excessive, or unnecessary access is identified and removed
Termination Deprovisioning (CO-04)	Access is removed or adjusted promptly when employment or engagement ends	Annex A 5.18 - Access rights	PR.AA — Identity Management, Authentication, and Access Control	Reduces the risk of terminated identities retaining access to organizational resources
Privileged Access (CO-05)	Privileged access is restricted, authorized, monitored, and periodically reviewed	Annex A 8.2 - Privileged access rights	PR.AA — Identity Management, Authentication, and Access Control	Reduces the risk associated with elevated permissions and administrative accounts
MFA Enforcement (CO-06)	Strong authentication, including MFA where required, is enforced for applicable accounts	Annex A 8.5 - Secure authentication	PR.AA — Identity Management, Authentication, and Access Control	Reduces the likelihood of unauthorized access resulting from compromised credentials